

บทที่ 2

ทฤษฎีพื้นฐานที่ใช้ในโครงงาน

ในบทนี้จะกล่าวถึง โครงสร้างของโปรแกรมแม่ข่ายและลูกข่ายสำหรับรับส่งสารด่วน นิยามความมั่นคงปลอดภัยของคอมพิวเตอร์ และ ทฤษฎีการสร้างผู้ให้บริการใบรับรองสิทธิ์ ซึ่งเนื้อหาทั้งหมดนี้จำเป็นสำหรับการศึกษา และประเมินประสิทธิภาพของโครงงาน

2. 1 โปรแกรมแม่ข่ายและลูกข่ายสำหรับรับส่งสารด่วน

ในระบบรับส่งสารด่วนจะแบ่งการทำงานเป็น 2 ส่วนหลักคือ

1. โปรแกรมแม่ข่ายสำหรับรับส่งสารด่วน(Instant Messaging Server)
2. โปรแกรมรับส่งสารด่วนฝั่งไคลเอนต์ (Instant Messaging Client)

โดยทั่วไปทุกครั้งก่อนที่ไคลเอนต์จะใช้บริการ ไคลเอนต์จำเป็นต้องทำการล็อกอินติดต่อไปยังโปรแกรมแม่ข่ายก่อนเสมอเนื่องจากโปรแกรมแม่ข่ายต้องการข้อมูลที่เป็นเบื้องต้นหลายๆ อย่างก่อนที่จะเริ่มการให้บริการแก่ไคลเอนต์ได้หากการล็อกอินสำเร็จอย่างสมบูรณ์โปรแกรมแม่ข่ายจะสามารถให้บริการด้านการส่งข้อความแก่ไคลเอนต์

หน้าที่ของโปรแกรมแม่ข่ายจะมากหรือน้อยขึ้นอยู่กับการออกแบบรูปแบบการติดต่อสื่อสาร รวมถึงความสามารถต่างๆที่โปรแกรมลูกข่ายต้องการ ซึ่งถ้ายิ่งมากแล้ว โปรแกรมแม่ข่ายก็ยังมีหน้าที่เพิ่มมากขึ้น

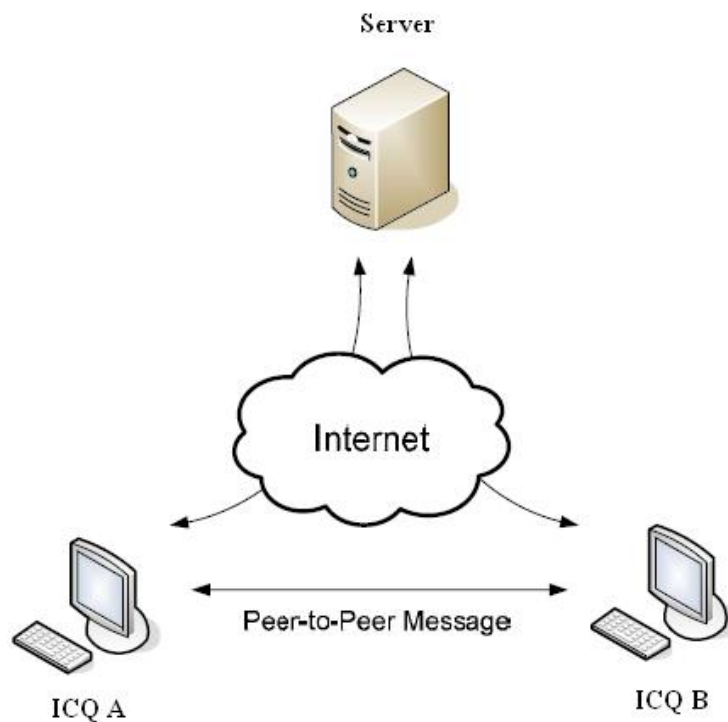
ชนิดของโปรแกรมรับส่งสารด่วนในปัจจุบัน

ในปัจจุบันระบบส่งสารด่วนแบ่งได้เป็น 2 ชนิดดังนี้

1. แบบเพียร์ทูเพียร์ (Peer-to-Peer Message)

การทำงานของระบบส่งสารด่วนแบบนี้ คือ เมื่อผู้ใช้งานต้องการใช้บริการก็จะทำการล็อกอินไปยังเซิร์ฟเวอร์ของโปรแกรมรับส่งสารด่วนเพื่อรับส่งรายละเอียดต่างๆ และเพื่อให้เซิร์ฟเวอร์เซิร์ฟเวอร์ทราบว่าขณะนี้ผู้ใช้คนใดที่อยู่ในสถานะพร้อมให้บริการเมื่อทำการแลกเปลี่ยนข้อมูลเสร็จสิ้นแล้ว เซิร์ฟเวอร์ก็จะแจ้งไปยังคู่สนทนาของผู้ใช้

หลังจากนั้นผู้ใช้งานจะสามารถติดต่อไปยังคู่สนทนาได้โดยตรงโดยไม่ผ่านเซิร์ฟเวอร์ซึ่งรูปแบบนี้เป็นลักษณะแบบเพียร์ทูเพียร์นั่นเองตัวอย่างของโปรแกรมรับส่งสารด่วนประเภทนี้ก็คือ ICQ



รูปที่ 2.1 ระบบส่งสารด่วนแบบเพียร์ทูเพียร์

2. แบบเซิร์ฟเวอร์ทำงานเป็นหลัก (Server-based Communication)

การทำงานของโปรแกรมรับส่งสารด่วนแบบนี้จะเริ่มค้นแบบเพียร์ทูเพียร์ต่างกันว่าเซิร์ฟเวอร์จะส่งเพียงชื่อหรือสถานะการออนไลน์หรือออฟไลน์ของกลุ่มสนทนาเท่านั้นของเซิร์ฟเวอร์จะเห็นได้ว่าวิธีนี้เป็นลักษณะรวมอำนาจเข้ามาไว้ที่ศูนย์กลาง(centralization)ผู้ใช้นอกจากจะต้องล็อกอินไปยังเซิร์ฟเวอร์แล้วทุกๆข้อความที่ผู้ใช้งานต้องการส่งไปให้ใครก็จำเป็นที่จะต้องส่งไปยังเซิร์ฟเวอร์เพื่อให้เซิร์ฟเวอร์ทำการส่งข้อความต่อไปยังผู้ใช้ปลายทางอีกทีหนึ่ง

ด้วยวิธีการนี้เซิร์ฟเวอร์จะต้องมีความสามารถนอกจากการให้บริการพื้นฐานแล้วยังต้องสามารถจัดลำดับการรับส่งข้อความของผู้ใช้ในเวลาจริงโดยข้อความใดมาก่อนก็จะได้การส่งไปยังปลายทางก่อนจะเห็นได้ว่าโปรแกรมทางฝั่งแม่ข่ายจะมีความซับซ้อนสูงมากตัวอย่างของระบบรับส่งสารด่วนประเภทนี้ก็คือ MSN Messenger

การเปรียบเทียบข้อดีข้อเสียของทั้งสองระบบ

ระบบส่งสารด่วนทั้งแบบเพียร์ทูเพียร์และแบบเซิร์ฟเวอร์ทำงานเป็นหลักต่างมีข้อดีข้อเสียแตกต่างกันไปซึ่งสามารถสรุปได้ดังนี้

ความสามารถ	เพียร์ทูเพียร์	แบบเซิร์ฟเวอร์
เซิร์ฟเวอร์ทำงานหนัก	มาก	น้อย
ความรวดเร็วในการส่งข้อความ	น้อย	น้อย
ความซับซ้อนของโปรโตคอล	น้อย	มาก
ความปลอดภัย	น้อย	มาก
ปัญหาเรื่องไฟล์วอลล์	มาก	น้อย
ค่าใช้จ่ายในการดูแลรักษา	น้อย	มาก

ตารางที่ 2.1 เปรียบเทียบคุณสมบัติระบบส่งสารผ่านแบบเพียร์ทูเพียร์และแบบเซิร์ฟเวอร์ทำงานเป็นหลัก

2.2 นิยามความมั่นคงปลอดภัยคอมพิวเตอร์

ในปัจจุบันระบบคอมพิวเตอร์ได้ถูกคุกคามมากขึ้นทั้งจากไวรัสคอมพิวเตอร์หรือจากผู้ไม่ประสงค์ดีซึ่งความมั่นคงปลอดภัยคอมพิวเตอร์(Computer Security) ช่วยปกป้องเครื่องคอมพิวเตอร์ รวมไปถึงอุปกรณ์ต่างๆที่เกี่ยวข้องและที่สำคัญยังสามารถช่วยปกป้องข้อมูลที่ได้จัดเก็บไว้ในระบบหรือใช้ในความหมายความปลอดภัยทางข้อมูลสารสนเทศ(Information Security)ก็ได้จุดประสงค์หลักของความปลอดภัยทางข้อมูลคือ ความลับ (Confidentiality) ความสมบูรณ์ (Integrity) ความพร้อมใช้ (Availability) และการห้ามปฏิเสธความรับผิดชอบ (Non-Repudiation) โดยมีรายละเอียดดังนี้

- การรักษาความลับ (Confidentiality) คือการรับรองว่าจะมีการเก็บข้อมูลไว้เป็นความลับและผู้มีสิทธิเท่านั้นจึงจะเข้าถึงข้อมูลนั้นได้
- การรักษาความสมบูรณ์ (Integrity) คือการรับรองว่าข้อมูลจะไม่ถูกเปลี่ยนแปลงหรือทำลายไม่ว่าจะเป็นโดย อุบัติเหตุหรือโดยเจตนา
- ความพร้อมใช้ (Availability) คือการรับรองว่าข้อมูลและบริการการสื่อสารต่าง ๆ พร้อมที่จะใช้ได้ในเวลาที่ต้องการใช้งาน
- การห้ามปฏิเสธความรับผิดชอบ (Non-Repudiation) คือวิธีการสื่อสารซึ่งผู้ส่งข้อมูลได้รับหลักฐานว่าได้มีการส่งข้อมูลแล้วและผู้รับก็ได้รับการยืนยันว่าผู้ส่งเป็นใคร ดังนั้นทั้งผู้ส่งและผู้รับจะไม่สามารถปฏิเสธได้ว่าไม่มีความเกี่ยวข้องกับข้อมูลดังกล่าวในภายหลัง

ในทางปฏิบัติสามารถกำหนดลักษณะของการควบคุมความมั่นคงปลอดภัย (Security Control) ได้ 5 ระดับดังรูป



รูปที่ 2.2 ลักษณะของการควบคุมความมั่นคงปลอดภัย (Security Control)

1.การพิสูจน์ตัวตน(Authentication)

การพิสูจน์ตัวตน คือขั้นตอนการยืนยันความถูกต้องของหลักฐาน (Identity) ที่แสดงว่าเป็นบุคคลที่กล่าวอ้างจริง ในทางปฏิบัติจะแบ่งออกเป็น 2 ขั้นตอน คือ

- การระบุตัวตน (Identification) คือขั้นตอนที่ผู้ใช้แสดงหลักฐานว่าตนเองคือใครเช่น ชื่อผู้ใช้ (username)
- การพิสูจน์ตัวตน (Authentication) คือขั้นตอนที่ตรวจสอบหลักฐานเพื่อแสดงว่าเป็นบุคคลที่กล่าวอ้างจริง

หลักฐานที่ผู้ใช้นำมากล่าวอ้างที่เกี่ยวกับเรื่องของความปลอดภัยนั้นสามารถจำแนกได้ 2 ชนิด

- Actual identity คือหลักฐานที่สามารถบ่งบอกได้ว่าในความเป็นจริงบุคคลที่กล่าวอ้างนั้นเป็นใคร
- Electronic identity คือหลักฐานทางอิเล็กทรอนิกส์ซึ่งสามารถบ่งบอกข้อมูลของบุคคลนั้นได้ แต่แต่ละบุคคลอาจมีหลักฐานทางอิเล็กทรอนิกส์ได้มากกว่า 1 หลักฐาน ตัวอย่างเช่น บัญชีชื่อผู้ใช้

กลไกของการพิสูจน์ตัวตน (Authentication mechanisms) สามารถแบ่งออกได้เป็น 3 คุณลักษณะคือ

- สิ่งที่คุณมี (Possession factor) เช่น กุญแจหรือเครดิตการ์ด เป็นต้น
- สิ่งที่คุณรู้ (Knowledge factor) เช่น รหัสผ่าน (passwords) หรือการใช้พิน (PINs) เป็นต้น

- สิ่งที่คุณเป็น (Biometric factor) เช่น ลายนิ้วมือ รูปแบบเรตินา (retinal patterns) หรือใช้รูปแบบเสียง (voice patterns) เป็นต้น

กระบวนการพิสูจน์ตัวตนนั้นจะนำ 3 ลักษณะข้างต้นมาใช้ในการยืนยันหลักฐานที่นำมากล่าวอ้างทั้งนี้ขึ้นอยู่กับระบบวิธีการที่นำมาใช้เพียงอย่างเดียวหนึ่ง (Single-factor authentication) นั้นมีข้อจำกัดในการใช้ ตัวอย่างเช่น สิ่งที่คุณมี (Possession factor) นั้นอาจจะสูญหายหรือถูกขโมยได้ สิ่งที่คุณรู้ (Knowledge factor) อาจจะถูกดักฟัง เคา หรือขโมยจากเครื่องคอมพิวเตอร์ สิ่งที่คุณเป็น (Biometric factor) จัดได้ว่าเป็นวิธีที่มีความปลอดภัยสูงอย่างไรก็ตามการที่จะใช้เทคโนโลยีนี้ได้นั้นจำเป็นต้องมีการลงทุนที่สูง เป็นต้น

ดังนั้นจึงได้มีการนำแต่ละคุณลักษณะมาใช้ร่วมกัน (multi-factor authentication) ตัวอย่างเช่น ใช้สิ่งที่คุณมีกับสิ่งที่คุณรู้มาใช้ร่วมกัน เช่น การใช้ลายมือชื่อร่วมกับการใช้บัตรเครดิตหรือการใช้รหัสผ่านร่วมกับการใช้บัตร ATM เป็นต้น การนำแต่ละลักษณะของการพิสูจน์ตัวตนมาใช้ร่วมกันมากกว่า 1 ลักษณะ จะช่วยเพิ่มประสิทธิภาพในการรักษาความปลอดภัยของข้อมูล

2.การกำหนดสิทธิ์ (Authorization)

การกำหนดสิทธิ์ คือขั้นตอนในการอนุญาตให้แต่ละบุคคลสามารถเข้าถึงข้อมูลหรือระบบใดได้บ้าง ก่อนอื่นต้องทราบก่อนว่าบุคคลที่กล่าวอ้างนั้นคือใครตามขั้นตอนการพิสูจน์ตัวตนและต้องให้แน่ใจด้วยการพิสูจน์ตัวตนนั้นถูกต้อง

3.การเข้ารหัส (Encryption)

การเข้ารหัสคือการเก็บข้อมูลให้เป็นส่วนบุคคลจากบุคคลอื่นที่ไม่ได้รับอนุญาต ส่วนประกอบ 2 ส่วนที่สำคัญที่จะช่วยให้ข้อมูลนั้นเป็นความลับได้ก็คือ การกำหนดสิทธิ์และการพิสูจน์ตัวตนเพราะว่าก่อนการอนุญาตให้บุคคลที่กล่าวอ้างเข้าถึงข้อมูลหรือถอดรหัสข้อมูลนั้นต้องสามารถแน่ใจได้ว่าบุคคลที่กล่าวอ้างนั้นเป็นใครและได้รับอนุญาตให้สามารถเข้ามาดูข้อมูลได้หรือไม่ ในการเข้ารหัสนั้นวิธีการหนึ่งที่ได้คือการเข้ารหัสในรูปแบบของกุญแจลับ (Secret key) ซึ่งในการใช้ก็รูปแบบนี้ต้องเฉพาะผู้ที่มีกุญแจลับนี้เท่านั้นที่สามารถรับข้อมูลที่เข้ารหัสแล้วได้

4. การรักษาความสมบูรณ์ (Integrity)

การรักษาความสมบูรณ์ คือการรับรองว่าข้อมูลจะไม่ถูกเปลี่ยนแปลงหรือทำลายไปจากต้นฉบับ (source) ไม่ว่าจะเป็นโดยบังเอิญหรือดัดแปลงโดยเจตนาที่อาจส่งผลเสียต่อข้อมูล การ

คุกคามความสมบูรณ์ของข้อมูลคือการที่บุคคลที่ไม่ได้รับอนุญาตสามารถที่จะเข้าควบคุมการจัดการของข้อมูลได้

5. การตรวจสอบ (Audit)

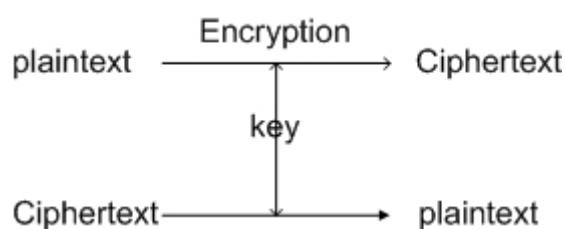
การตรวจสอบ คือการตรวจสอบหลักฐานทางอิเล็กทรอนิกส์ ซึ่งสามารถใช้ในการติดตามการดำเนินการเพื่อตรวจสอบความถูกต้องและแม่นยำ ตัวอย่างเช่นการตรวจสอบบัญชีผู้ใช้ โดยผู้ตรวจบัญชี ซึ่งการตรวจสอบความถูกต้องของการดำเนินการเพื่อให้แน่ใจว่าหลักฐานทางอิเล็กทรอนิกส์นั้นได้ถูกสร้างและสั่งให้ทำงานโดยบุคคลที่ได้รับอนุญาต และในการเชื่อมต่อเหตุการณ์เข้ากับบุคคลจะต้องทำการตรวจสอบหลักฐานของบุคคลนั้นด้วย ซึ่งถือเป็นหลักการพื้นฐานของขั้นตอนการทำงานของระบบพิสูจน์ตัวตนด้วย

การพิสูจน์ตัวตนจึงเป็นการตรวจสอบหลักฐานขั้นพื้นฐานที่สำคัญที่สุดใน 5 ระดับชั้นของการควบคุมความปลอดภัย ดังนั้นการพิสูจน์ตัวตนจะช่วยเพิ่มความมั่นคงปลอดภัยขั้นพื้นฐานให้กับระบบมากยิ่งขึ้น

2.2.1 ศาสตร์แห่งการเข้ารหัสลับ(Cryptography)

การเข้ารหัสลับคือศาสตร์ที่ว่าด้วย การเข้ารหัสลับ(Encryption) และการถอดรหัสลับ (Decryption) ซึ่งจะช่วยในการรักษาความลับของข้อมูล โดยสามารถแบ่งตามลักษณะของกุญแจได้ 2 ชนิดคือ การเข้ารหัสลับด้วยกุญแจลับ (Secret Key Cryptography) และแบบการเข้ารหัสลับด้วยกุญแจสาธารณะ (Public Key Cryptography)

การเข้ารหัสลับด้วยกุญแจลับ (Secret Key Cryptography) การเข้ารหัสลับแบบนี้จะใช้กุญแจอันเดียว เมื่อนำข้อความ (Plaintext) และกุญแจมาเข้ารหัสลับผลที่ได้จะเป็นข้อมูลที่ไม่สามารถเข้าใจความหมายได้ (ciphertext) ซึ่งปกติความยาวของ ciphertext จะเท่ากับความยาวของข้อความด้านการถอดรหัสลับก็คือการทำย้อนกลับของการเข้ารหัสลับและใช้กุญแจเดิมในการถอดรหัส



รูปที่ 2.3 การการเข้ารหัสลับและการถอดรหัสลับ

ในบางทีการเข้ารหัสลับด้วยกุญแจลับจะเรียกว่าการเข้ารหัสแบบสมมาตร(symmetric cryptography)

การเข้ารหัสลับด้วยกุญแจลับกับความปลอดภัย

การใช้การเข้ารหัสลับด้วยกุญแจลับสามารถนำไปใช้ในการสร้างความปลอดภัยในระบบได้หลายอย่าง เช่น การส่งข้อมูลผ่านช่องทางที่ไม่ปลอดภัย

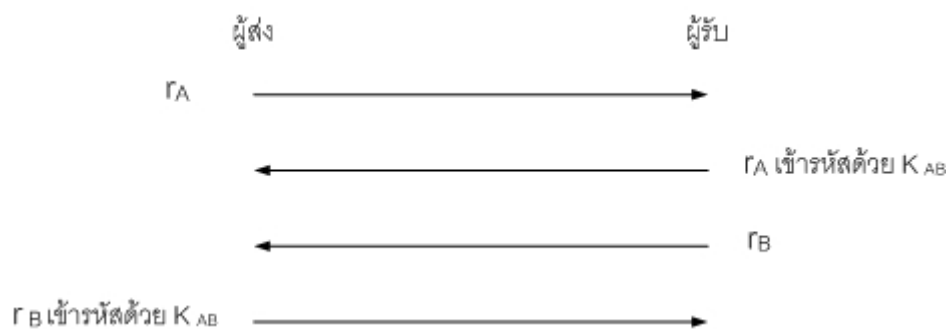
การส่งข้อมูลผ่านตัวกลางนั้นมีโอกาสที่จะโดนดักจับข้อมูลได้ง่าย จึงมีการนำการเข้ารหัสลับด้วยกุญแจลับมาใช้โดยผู้รับกับผู้ส่งจะต้องรู้ความลับร่วมกัน(กุญแจ) เมื่อจะส่งข้อมูลผู้ส่งก็จะเข้ารหัสลับข้อมูลผู้รับก็เพียงแค่นำข้อมูลที่เข้ารหัสมาถอดรหัส วิธีนี้ผู้ประสงค์ร้ายก็ยังสามารถดักจับข้อมูลได้ แต่ข้อมูลที่ได้ไปก็ไม่สามารถเข้าใจได้ ข้อเสียของวิธีนี้คือผู้ที่รู้ความลับร่วมสามารถถอดรหัสลับได้ถึงแม้จะไม่ใช่ว่าเราต้องการสื่อสารด้วย

การเก็บข้อมูลให้ปลอดภัยบนตัวกลางที่ไม่ปลอดภัย

การเก็บข้อมูลสามารถนำการเข้ารหัสลับด้วยกุญแจลับไปประยุกต์ใช้โดยมีการเข้ารหัสข้อมูลก่อนที่จะเก็บลงบนตัวกลางด้วยวิธีนี้ก็จะไม่มีใครสามารถอ่านข้อมูลได้ถ้าไม่รู้คีย์ แต่ข้อเสียของวิธีนี้คือถ้า ผู้ที่เป็นเจ้าของกุญแจลับทำกุญแจลับหายก็จะไม่สามารถอ่านข้อมูลได้

การระบุตัวตน (Authentication)

เมื่อผู้รับกับผู้ส่งต้องการที่จะระบุตัวตนสามารถทำได้โดยสมมติว่าผู้ใช้ทั้งสองคนรู้ความลับร่วมกันคือ K_{AB} ทั้งสองคนก็จะสุ่มตัวเลขขึ้นมาเรียกว่า challenge สมมติว่า ผู้ส่งเลือก r_A ผู้รับเลือก r_B ค่า x ก็จะโดนเข้ารหัสลับด้วยกุญแจซึ่งจะเรียกว่า respond



รูปที่ 2.4 การเข้ารหัสลับด้วยกุญแจลับ

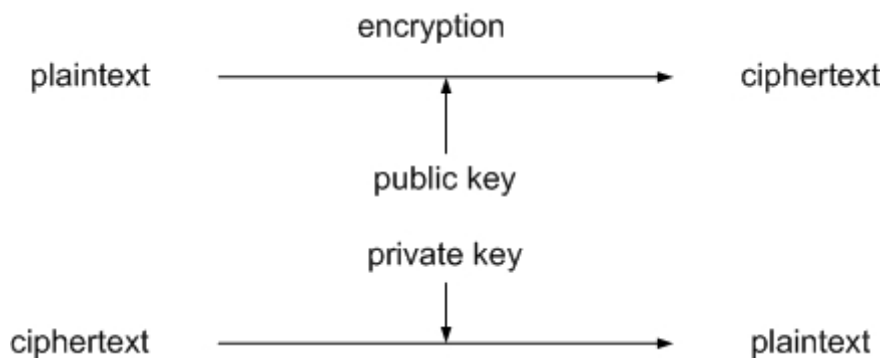
การตรวจสอบความครบถ้วนสมบูรณ์(Integrity check)

การเข้ารหัสลับด้วยกุญแจลับสามารถนำไปใช้ตรวจสอบความครบถ้วนสมบูรณ์ของข้อมูล โดยสามารถใช้ เพื่อสร้าง checksum ของข้อมูลแต่ไม่เป็นที่ยอมรับเนื่องจากผู้ประสงค์ร้ายสามารถ แก้ไขข้อมูลแล้วคิด checksum ใหม่ได้

การเข้ารหัสลับด้วยกุญแจสาธารณะ (Public Key Cryptography)

การเข้ารหัสลับด้วยกุญแจสาธารณะหรือบางที่เรียกว่าการเข้ารหัสลับแบบไม่สมมาตร (Asymmetric cryptography) การใช้กุญแจสาธารณะในการเข้ารหัสลับมีแนวคิดที่ต่างจากการใช้ กุญแจลับคือ แทนที่จะต้องมีการรู้ความลับร่วมในกุญแจแต่ละชุดจะประกอบด้วยกุญแจ 2 อัน คือ กุญแจส่วนตัว (Private key) ซึ่งต้องเก็บไว้ไม่ให้ใครรู้และกุญแจสาธารณะ (Public Key) ซึ่งจะ แจกจ่ายไป

ในการเข้ารหัสลับด้วยกุญแจสาธารณะจะใช้กุญแจสาธารณะในการเข้ารหัสและใช้กุญแจ ส่วนตัวในการถอดรหัสซึ่งการเข้ารหัสลับและถอดรหัสลับนั้นจะสร้างจากฟังก์ชันทางคณิตศาสตร์ ที่อินเวอร์สกัน



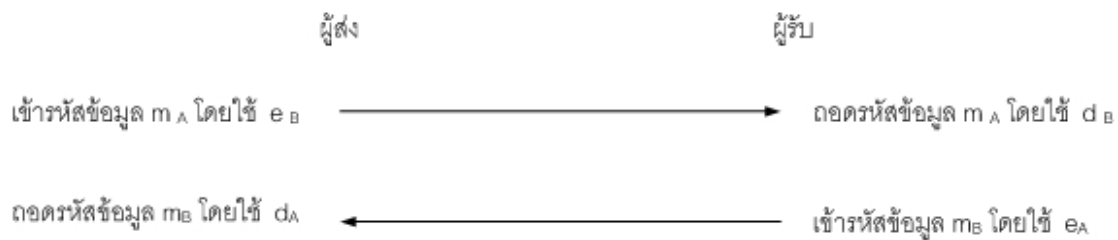
รูปที่ 2.5 การเข้ารหัสลับด้วยกุญแจสาธารณะ

2.2.2 การเข้ารหัสลับด้วยกุญแจสาธารณะกับความปลอดภัย

การเข้ารหัสลับด้วยกุญแจสาธารณะสามารถทำทุกอย่างที่การเข้ารหัสลับด้วยกุญแจลับได้ แต่อัลกอริทึมที่ใช้สร้างกุญแจสาธารณะนั้นช้ากว่าอัลกอริทึมที่ใช้สร้างกุญแจลับมากซึ่งปกติแล้วการเข้ารหัสลับด้วยกุญแจสาธารณะจะใช้ร่วมกับการเข้ารหัสลับด้วยกุญแจลับ การเข้ารหัสลับด้วย กุญแจสาธารณะใช้กันอย่างกว้างขวาง เพราะระบบความปลอดภัยในเครือข่ายมีรากฐานมาจาก เทคโนโลยีของกุญแจสาธารณะ

การส่งข้อมูลผ่านช่องทางที่ไม่ปลอดภัย

สมมติว่าผู้ส่งมีคู่กุญแจสาธารณะ, กุญแจส่วนตัว คือ (e_A, d_A) และของผู้รับคือ (e_B, d_B) สมมติว่าผู้ส่งรู้กุญแจสาธารณะของผู้รับและผู้รับรู้กุญแจสาธารณะของผู้ส่ง



รูปที่ 2.6 การเข้ารหัสลับด้วยกุญแจสาธารณะและถอดด้วยกุญแจลับ

การเก็บข้อมูลให้ปลอดภัยบนตัวกลางที่ไม่ปลอดภัย

วิธีที่ใช้จะเหมือนกับแบบที่ใช้กุญแจลับ โดยเข้ารหัสลับข้อมูลโดยใช้ กุญแจสาธารณะก็จะไม่มีใครสามารถอ่านข้อมูลได้แล้วถอดรหัสโดยใช้กุญแจส่วนตัวแต่ถ้าต้องการความรวดเร็วอาจจะไม่ต้องใช้กุญแจส่วนตัวในการเข้ารหัส แต่สุ่มกุญแจลับขึ้นมาและเข้ารหัสลับข้อมูลด้วยกุญแจลับ และเข้ารหัสลับกุญแจลับด้วยกุญแจสาธารณะ

การใช้กุญแจสาธารณะมีข้อดีที่เหนือกว่ากุญแจลับ คือ ผู้ส่งสามารถเข้ารหัสลับข้อมูลได้โดยไม่ต้องรู้กุญแจสำหรับถอดรหัสลับ

การระบุตัวตน (Authentication)

ในการระบุตัวตนโดยใช้กุญแจลับผู้รับและผู้ส่งถ้าต้องการติดต่อสื่อสารกันจำเป็นต้องรู้ความลับร่วมกัน ถ้าผู้ส่งต้องการพิสูจน์ตัวตนของผู้รับหลายๆ คนถ้าใช้วิธีของกุญแจลับผู้ส่งก็ต้องเก็บความลับไว้มากมายซึ่งการใช้กุญแจสาธารณะในการระบุตัวตนจะสะดวกกว่าซึ่งการใช้กุญแจสาธารณะทำให้ผู้ส่งจดจำแค่กุญแจส่วนตัวของตัวเอง ตัวอย่างดังรูป



รูปที่ 2.7 การระบุตัวตนโดยใช้กุญแจลับ

2.3 ทฤษฎีสำหรับการส่งข้อมูลบนอินเทอร์เน็ตให้ปลอดภัยด้วย SSL

ในระหว่างการพัฒนาเครือข่ายอินเทอร์เน็ตในระยะเริ่มแรกนั้น ไม่ได้มีการเน้นในการพัฒนาด้านความปลอดภัยในการส่งข้อมูลบนเครือข่าย เนื่องจากในระบะนั้นเครือข่ายอินเทอร์เน็ตนี้ถูกใช้ในการติดต่อสื่อสารระหว่างกลุ่มนักวิจัยในมหาวิทยาลัยและสถาบันต่างๆ ไม่กี่กลุ่ม ซึ่งมีความรู้จักคุ้นเคยกันและมีความเชื่อถือต่อกันและกันดังนั้นข้อมูลที่ถูกส่งไปบนเครือข่ายอินเทอร์เน็ตจึง

เป็นลักษณะของข้อมูลที่ไม่ได้เข้ารหัสลับใดๆจนทุกวันนี้การส่งข้อมูลส่วนใหญ่บนเครือข่ายอินเทอร์เน็ตก็ยังคงลักษณะนี้อยู่

ในปัจจุบัน ผู้ใช้เครือข่ายอินเทอร์เน็ตมีจำนวนเพิ่มขึ้นอย่างมากและเครือข่ายนี้ถูกใช้งานในรูปแบบต่างๆมากมายหลายรูปแบบ โดยเฉพาะอย่างยิ่งในการพาณิชย์อิเล็กทรอนิกส์(e-commerce) ซึ่งผู้ซื้อและผู้ขายจะต้องส่งข้อมูลที่เป็นความลับถึงกันและกัน เช่นผู้ซื้อส่งหมายเลขบัตรเครดิตหรือที่อยู่และเบอร์โทรศัพท์โดยส่งผ่านไปบนเครือข่ายอินเทอร์เน็ตหากข้อมูลเหล่านี้ถูกส่งไปแบบธรรมดา ก็จะเป็นการค่อนข้างง่ายที่ผู้ไม่หวังดีจะสามารถดักจับข้อมูลเหล่านี้ (sniffing) แล้วนำไปใช้ได้ เนื่องจากข้อมูลเหล่านี้อยู่ในรูปของข้อความที่ไม่ได้เข้ารหัส ผู้ดักจับข้อมูลก็จะสามารถนำข้อมูลนั้นไปใช้ได้ทันที

ในอีกกรณีหนึ่งบนเครือข่ายอินเทอร์เน็ตนี้ผู้ใช้สามารถเชื่อมต่อและใช้งานเครื่องคอมพิวเตอร์ใดๆก็ได้หากผู้ใช้นั้นได้รับอนุญาตและสามารถพิสูจน์ตนเองโดยชื่อผู้ใช้และรหัสผ่านที่ถูกต้องบนเครื่องนั้นๆ โดยจะมีโปรแกรมที่ใช้ช่วยในการเชื่อมต่อและใช้งานนั้น เช่น telnet, rsh, rlogin, rcp, และ ftp เป็นต้นโปรแกรมเหล่านี้ส่งข้อมูลตามแบบมาตรฐานดั้งเดิมของเครือข่าย Internet กล่าวคือส่งข้อมูลทุกอย่าง(รวมทั้งชื่อผู้ใช้และรหัสผ่าน)ในรูปของข้อความที่ไม่ได้เข้ารหัส ดังนั้นหากมีผู้ดักจับข้อมูลเกี่ยวกับชื่อผู้ใช้และรหัสผ่านได้ผู้ใช้นั้นก็จะสามารถนำเอาชื่อผู้ใช้และรหัสผ่านนี้ไปใช้ในการเชื่อมต่อและใช้งานเครื่องคอมพิวเตอร์เครื่องนั้นได้ต่อไป

เนื่องจากปัญหาที่กล่าวมานี้เป็นปัญหาที่ค่อนข้างใหญ่เพราะการsniffingนั้นสามารถกระทำได้อย่างค่อนข้างง่ายจึงได้มีการคิดแก้ไขปัญหานี้ขึ้นโดย Netscape ได้คิดค้นโปรโตคอลใหม่ขึ้นมาคือ Secure Socket Layer Protocol (SSL) และโปรแกรมเมอร์ชาว Finland ได้เขียนโปรแกรมขึ้นชุดหนึ่ง เรียกว่า Secure Shell (SSH) ซึ่งทั้ง SSL และ SSH จะเข้ารหัสลับข้อมูลใดๆก่อนที่จะข้อมูลนั้นจะถูกส่งไปบนเครือข่ายอินเทอร์เน็ต ดังนั้น หากผู้ไม่หวังดีสามารถดักจับข้อมูลนั้นไปได้ ผู้ใช้นั้นก็ไม่สามารถที่จะนำข้อมูลนั้นไปใช้ได้เพราะเขาไม่สามารถตีความข้อมูลนั้นได้

SSL นั้นได้รับการยอมรับอย่างกว้างขวางบน world wide web ในการใช้สำหรับตรวจสอบและเข้ารหัสลับการติดต่อสื่อสารระหว่างไคลเอ็นต์และเซิร์ฟเวอร์หน้าที่ของ SSL จะแบ่งออกเป็น 3 ส่วนใหญ่ๆคือ

1. การตรวจสอบเซิร์ฟเวอร์ว่าเป็นตัวจริง : ตัวโปรแกรมไคลเอ็นต์ที่มีขีดความสามารถในการสื่อสารแบบSSLจะสามารถตรวจสอบหรือ เซิร์ฟเวอร์ ที่ตนกำลังจะไปเชื่อมต่อได้ว่า เซิร์ฟเวอร์นั้นเป็นเซิร์ฟเวอร์ตัวจริงหรือไม่ โดยใช้เทคนิคการเข้ารหัสแบบกุญแจสาธารณะ(public key) ในการตรวจสอบใบรับรองสิทธิ์ (certificate) และ public ID ของ เซิร์ฟเวอร์ นั้น (โดยที่มีองค์กรที่ไคลเอ็นต์เชื่อถือเป็นผู้ออกใบรับรองสิทธิ์และ public ID ให้แก่ เซิร์ฟเวอร์นั้น)

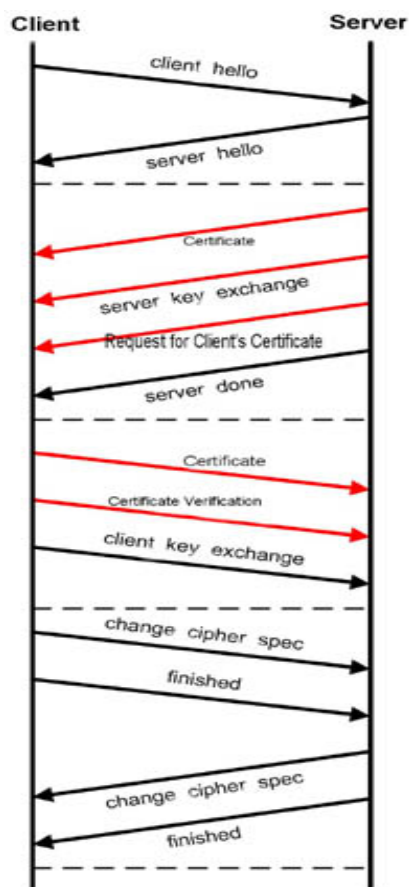
หน้าที่หนึ่งของ SSL เป็นหน้าที่ที่สำคัญ โดยเฉพาะอย่างยิ่งในกรณีที่ โคลเอ็นต์ ต้องการที่จะส่งข้อมูลที่เป็นความลับ (เช่น หมายเลข credit card) ให้กับเซิร์ฟเวอร์ซึ่งโคลเอ็นต์จะต้องตรวจสอบก่อนว่าเซิร์ฟเวอร์เป็นตัวจริงหรือไม่

2. การตรวจสอบว่าโคลเอ็นต์เป็นตัวจริง : เซิร์ฟเวอร์ที่มีขีดความสามารถในการสื่อสารแบบSSLจะใช้เทคนิคเช่นเดียวกับในหัวข้อที่แล้วในการตรวจสอบโคลเอ็นต์หรือผู้ใช้งานว่าเป็นตัวจริงหรือไม่โดยจะตรวจสอบใบรับรองและpublic ID (ที่มีองค์กรที่ เซิร์ฟเวอร์เชื่อถือเป็นผู้ออกให้) ของโคลเอ็นต์หรือผู้ใช้นั้น

หน้าที่หนึ่งของ SSL จะมีประโยชน์ในกรณีเช่น ธนาคารต้องการที่จะส่งข้อมูลลับทางการเงินให้แก่ลูกค้าของตนผ่านทางเครือข่ายอินเทอร์เน็ต(เซิร์ฟเวอร์ ก็จะต้องตรวจสอบ โคลเอ็นต์ ก่อนว่าเป็น โคลเอ็นต์ นั้นจริง)

3. การเข้ารหัสลับการเชื่อมต่อ : ในกรณีนี้ ข้อมูลทั้งหมดที่ถูกส่งระหว่างโคลเอ็นต์และเซิร์ฟเวอร์จะถูกเข้ารหัสลับโดยโปรแกรมที่ส่งข้อมูลเป็นผู้เข้ารหัสและโปรแกรมที่รับข้อมูลเป็นผู้ถอดรหัส(โดยใช้วิธีแบบกุญแจสาธารณะ)นอกจากการเข้ารหัสลับในลักษณะนี้แล้ว SSL ยังสามารถปกป้องความถูกต้องสมบูรณ์ของข้อมูลได้อีกด้วย กล่าวคือ ตัวโปรแกรมรับข้อมูลจะทราบได้หากข้อมูลถูกเปลี่ยนแปลงไปในขณะกำลังเดินทางจากผู้ส่งไปยังผู้รับ

ทฤษฎีทางการสร้างการเชื่อมต่อแบบ SSL



รูปที่ 2.8 ขั้นตอนการสร้างการเชื่อมต่อของ SSL

1. ClientHelloจะเป็นข้อความที่ไคลเอนต์ใช้สำหรับเริ่มต้นการสื่อสารด้วยSSLโปรโตคอล โดยข้อความนี้จะเป็นการนำเสนอค่าพารามิเตอร์ต่าง ๆ ที่ตัวเองสามารถรองรับได้ส่งไปให้แก่เซิร์ฟเวอร์

2. ServerHello เมื่อเซิร์ฟเวอร์ได้รับข้อความ ClientHello เซิร์ฟเวอร์จะทำการตอบกลับด้วย ServerHello ไคลเอนต์จะนำเสนอค่าพารามิเตอร์ต่างๆ ให้แก่เซิร์ฟเวอร์ เซิร์ฟเวอร์จะทำการเลือกค่าพารามิเตอร์เหล่านั้นแล้วส่งกลับไปด้วยข้อความ ServerHello

3. Certificate เพื่อพิสูจน์ตัวตนของเซิร์ฟเวอร์ จากรูปไคลเอนต์จะมีกุญแจสาธารณะของ CAที่เป็นCAที่เซิร์ฟเวอร์ได้นำข้อมูลต่างๆไปให้CAนั้นทำการSignให้โดยข้อความCertificateของฝั่งเซิร์ฟเวอร์จะประกอบไปด้วยกุญแจสาธารณะของเซิร์ฟเวอร์และข้อมูลได้รับการSign มาจาก CA นั้น ส่งไปให้แก่ไคลเอนต์

4. ServerKeyExchange เซิร์ฟเวอร์จะทำการส่งข้อความ ServerKeyExchange ไปให้แก่ฝั่งไคลเอนต์ ในขณะที่ฟิลด์ CipherSuite จะเป็นตัวบอกลักษณะของอัลกอริทึมและขนาดของคีย์ข้อความ และส่งคีย์สาธารณะไปด้วย

5. Request for Client's Certificate จะเป็นข้อความจากเซิร์ฟเวอร์ที่เป็นการบอกให้แก่ไคลเอนต์ทราบว่าเซิร์ฟเวอร์มีความต้องการที่จะทำการพิสูจน์ตัวตนของไคลเอนต์

6. Server done จะเป็นข้อความที่บอกให้ไคลเอนต์ทราบว่าเซิร์ฟเวอร์ได้ส่งข้อมูลที่ใช้สำหรับการเริ่มต้นการติดต่อสื่อสารเรียบร้อยแล้วซึ่งข้อความนี้จะไม่มีข้อมูลใดๆแต่มันเป็นสิ่งสำคัญต่อไคลเอนต์จะต้องได้รับข้อความนี้ก่อนไคลเอนต์จึงจะสามารถกระทำเฟสต่อไปของการสร้างการเชื่อมต่อที่ปลอดภัยโดยใช้ SSL โพรโทคอลได้

7. Certificate เป็นข้อความของฝั่งไคลเอนต์ที่เป็นข้อมูลที่ไคลเอนต์ได้รับจากการส่งข้อมูลของไคลเอนต์ เช่น อนุญาตสาธารณะของไคลเอนต์ไปให้แก่ CA ที่เซิร์ฟเวอร์เชื่อถือทำการ Sign ข้อมูลดังกล่าว

8. Certificate Verification เป็นข้อมูลของอนุญาตสาธารณะที่ไคลเอนต์ใช้ในการพิสูจน์ตัวตน

9. Client key exchange เมื่อไคลเอนต์ได้รับข้อความ Certificate จากเซิร์ฟเวอร์ จะใช้ฟังก์ชัน Verify() ในการพิสูจน์ตัวตนของเซิร์ฟเวอร์ถ้าพิสูจน์ตัวตนถูกต้องไคลเอนต์จะนำอนุญาตสาธารณะของเซิร์ฟเวอร์ที่ได้ส่งมาด้วยนั้นนำมาเข้ารหัสกุญแจลับที่ได้สร้างขึ้นมา

10. Change cipher spec หลังจากที่ได้ไคลเอนต์ส่งข้อความ ClientKeyExchange เรียบร้อยแล้วจะถือว่าสิ้นสุดการต่อรองค่าพารามิเตอร์ต่าง ๆ ระหว่างไคลเอนต์กับเซิร์ฟเวอร์ ณ จุดนี้ทั้งสองระบบสามารถที่จะสื่อสารกันได้อย่างปลอดภัยโดยใช้ SSL โพรโทคอลข้อความ ChangeCipherSpec จะเป็นข้อความที่ชี้ให้เห็นอย่างชัดเจนว่าการรับข้อมูลอย่างปลอดภัยโดยใช้ SSL โพรโทคอลสามารถทำงานได้แล้ว

11. Finished ทันทีหลังจากที่ได้ทำการส่งข้อความ ChangeCipherSpec แต่ละระบบจะทำการส่งข้อความ Finished ซึ่งเป็นข้อความที่ใช้ตรวจสอบความถูกต้องของข้อมูลที่ได้ทำการส่งไป เช่น ข้อมูลเกี่ยวกับคีย์ รายละเอียดเกี่ยวกับการต่อรองค่าพารามิเตอร์ต่างๆ ในครั้งก่อน และข้อมูลใดๆ ที่จะเป็นการตัวระบุตัวตนของทั้งเซิร์ฟเวอร์และไคลเอนต์ โดยค่าเหล่านี้จะต้องทำให้เป็นแฮชแวล (hash value) ก่อนทำการส่งออกไป

2.4 ทฤษฎีใบรับรองสิทธิ์(Certificate)

การเข้ารหัสลับให้กับข้อความอาจไม่เพียงพอกับความปลอดภัยเนื่องจากอาจเกิดปัญหา man-in-the-middle ได้ โครงงานนี้จึงได้เพิ่มใบรับรองสิทธิ์ซึ่งใช้ในการพิสูจน์ตัวตนว่าผู้ที่เรากำลังติดต่ออยู่ด้วยเป็นบุคคลเดียวกันกับที่เราเข้าใจ

2.4.1 ปัญหา man-in-the-middle

กระบวนการการทำงานของโพรโตคอลSSL ที่ใช้การเข้ารหัสข้อมูลเพียงอย่างเดียวระหว่างสองระบบนั้นมันยังไม่มีความปลอดภัยเพียงพอ เมื่อ Alice ที่มีบทบาทเป็นไคลเอ็นต์และ Bob ที่มีบทบาทเป็นเซิร์ฟเวอร์ และมีบุคคลที่อยู่ตรงกลางชื่อว่า Trudy โดยขั้นแรก Trudy จะแสดงบทบาทตัวเองเป็น Alice โดยบอก Bob ว่า “I’m Alice” และ Bob จะส่งข้อความว่า “I’m Bob” พร้อมส่งกุญแจสาธารณะของตนเองให้แก่ Trudy ซึ่งในขณะนี้ได้ปลอมตัวเป็น Alice เมื่อได้กุญแจสาธารณะของ Bob Trudy จะทำการสร้างกุญแจลับขึ้นมาแล้วใช้กุญแจสาธารณะของ Bob มาเข้ารหัสกุญแจลับที่ได้สร้างขึ้นมาเสร็จแล้วก็ทำการส่งข้อมูล (Cipher text) นั้นให้แก่ Bob ณ จุดนี้ Trudy สามารถที่จะติดต่อสื่อสารกับ Bob ได้ จากนั้น Trudy จะทำการปลอมตัวตัวเองให้เป็น Bob ที่มีบทบาทเป็นเซิร์ฟเวอร์ โดย Trudy จะรับข้อความจาก Alice ว่า “I’m Bob” พร้อมส่งกุญแจสาธารณะของตนเองให้แก่ Alice ณ ตอนนี้ Trudy ก็สามารถติดต่อสื่อสารกับ Alice ได้ เมื่อถึงจุดนี้ Trudy จะทราบข้อมูลทุกอย่างที่ Bob กับ Alice ติดต่อกัน ดังนั้น Trudy สามารถสร้างความเสียหายให้แก่ Bob และ Alice ได้ โพรโตคอลได้ทำการแก้ไขปัญหาดังกล่าวโดยได้เพิ่มวิธีการที่เรียกว่าการพิสูจน์ตัวตนโดยใช้ใบรับรองสิทธิ์

2.4.2 ใบรับรองสิทธิ์(Certificate)

คำจำกัดความง่ายๆ ของใบรับรองสิทธิ์ก็คือใบรับรองสิทธิ์จะผนึกรวมกุญแจสาธารณะกับชื่อพิเศษชื่อพิเศษคือชื่อของบุคคลหรือสิ่งซึ่งเป็นเจ้าของกุญแจสาธารณะใบรับรองสิทธิ์ก็เปรียบเหมือนหนังสือเดินทางซึ่งผนึกรูปภาพกับชื่อเพื่อเป็นเอกลักษณ์ของแต่ละบุคคลใบรับรองสิทธิ์ดิจิทัล โดยบุคคลที่สามซึ่งเชื่อถือได้โดยประกอบด้วยข้อมูลเกี่ยวกับบุคคลที่สามที่ตีพิมพ์ใบรับรองสิทธิ์นั้นในใบรับรองสิทธิ์ยังมีเครื่องหมายป้องกันซึ่งมีจุดมุ่งหมายเพื่อการพิสูจน์ตัวตนและเพื่อป้องกันการปลอมแปลงและ tampering ใบรับรองสิทธิ์ใช้ได้ในช่วงเวลาที่กำหนดเมื่อหมดอายุจะต้องออกใบรับรองสิทธิ์ใหม่และใบรับรองสิทธิ์เก่าจะไม่ได้รับการเชื่อถืออีกต่อไป

ใบรับรองสิทธิ์จะเซ็น(Sign)โดยด้วยกุญแจส่วนตัวของผู้ออกใบรับรองสิทธิ์และประกอบด้วยข้อมูลที่จำเป็นเพื่อพิสูจน์ความถูกต้องซึ่งข้อมูลเหล่านี้ประกอบด้วยรายละเอียดต่างๆไป,ผู้ออกใบรับรองสิทธิ์และช่วงเวลาที่ใบรับรองสิทธิ์นั้นมีผล ส่วนประกอบที่เป็นกุญแจสำคัญคือ ใบรับรอง

สิทธิของผู้ออกใบรับรองสิทธิสำหรับพิสูจน์ว่าใบรับรองสิทธินั้นออกโดยผู้ออกใบรับรองสิทธินั้นจริงๆ เพราะว่ามันประกอบด้วยกุญแจสาธารณะของผู้ออกใบรับรองสิทธิซึ่งจำเป็นในการพิสูจน์ลายเซ็นของใบรับรองสิทธินั้น

การเซ็นใบรับรองสิทธิด้วยกุญแจส่วนตัวของผู้ออกใบรับรองสิทธิ ใครก็ตามที่มีกุญแจสาธารณะของผู้ออกใบรับรองสิทธิสามารถพิสูจน์ตัวตนได้, ลายเซ็นทำหน้าที่เป็นเครื่องป้องกันการ tampering เมื่อผู้ออกใบรับรองสิทธิเซ็นใบรับรองสิทธิของผู้ที่ร้องก็สามารถยืนยันว่าได้ตรวจสอบความเป็นจริงของกุญแจสาธารณะซึ่งบรรจุในใบรับรองสิทธิและสถานะความน่าเชื่อถือเมื่อใดก็ตาม ที่ยังเชื่อถือผู้ออกใบรับรองสิทธิใบรับรองสิทธิที่ออกโดยผู้ออกใบรับรองสิทธิก็สามารถเชื่อถือได้

ใบรับรองสิทธิสร้างพร้อมกับหมายเลขซีเรียล ซึ่งจะบรรจุอยู่ใน ซึ่งหมายเลขซีเรียลนี้จะไม่ซ้ำกันในแต่ละใบรับรองสิทธิที่ออกโดยผู้ออกใบรับรองสิทธิ หมายเลขซีเรียลของใบรับรองสิทธิ มักจะใช้เพื่อจำแนกใบรับรองสิทธิได้อย่างรวดเร็ว

2.5 ทฤษฎีการสร้างผู้ให้บริการใบรับรองสิทธิ(Certification Authorities)

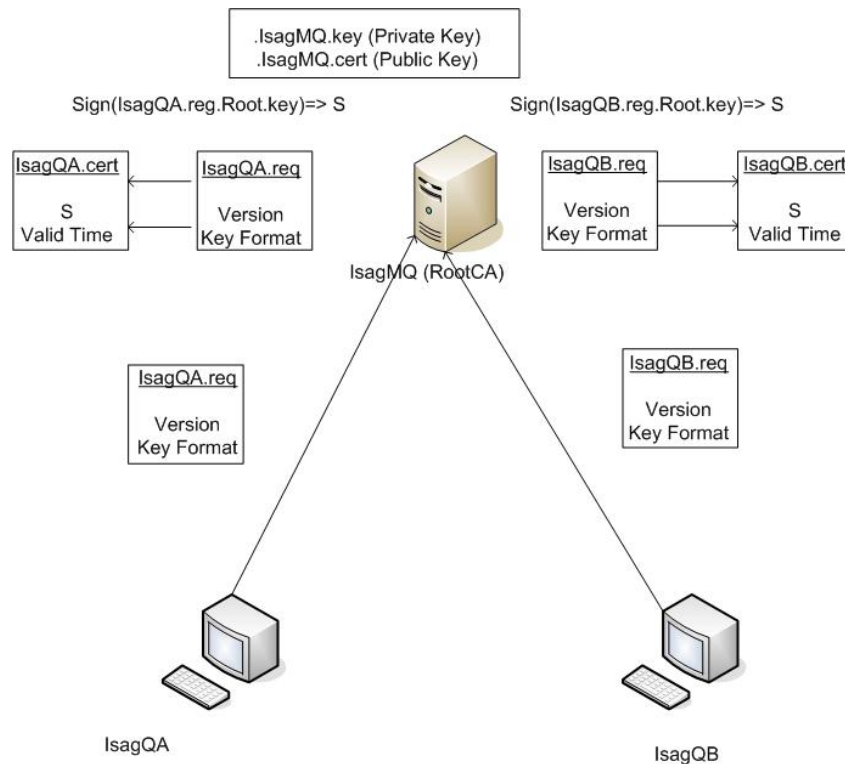
ผู้ให้บริการใบรับรองสิทธิมีอยู่ 2 ชนิดคือ Private CA และ Public CA โดยโครงการนี้เป็นแบบแรก ซึ่งจะออกใบรับรองให้เฉพาะ IsagQ ซึ่งเป็น Self-sign CA

2.5.1 ผู้ให้บริการใบรับรองสิทธิ(Certification Authorities)

Certification Authorities(CA) คือ องค์กรหรือบริษัทซึ่งทำหน้าที่ออกใบรับรองสิทธิ, CA มีสิ่งที่จะต้องรับผิดชอบคือใบรับรองสิทธิที่ออกต้องถูกต้องสมบูรณ์ นั่นคือ CA ต้องทำให้แน่ใจว่าใบรับรองสิทธิทุกๆ ใบที่ออกไปบรรจุกุญแจสาธารณะที่ออกโดยฝ่ายที่ร้องขอจริงๆ

CA แบ่งได้เป็น 2 ชนิดคือ Private CA ซึ่งรับผิดชอบการออกใบรับรองสิทธิเฉพาะสมาชิกขององค์กรที่เป็นเจ้าของและเชื่อถือได้เพื่อสมาชิกขององค์กรที่เป็นเจ้าของทางด้าน Public CA เช่น Verisign , Thwate มีหน้าที่รับผิดชอบในการออกใบรับรองสิทธิให้กับใครก็ได้ที่ต้องการและต้องได้รับความเชื่อถือจากสาธารณะ

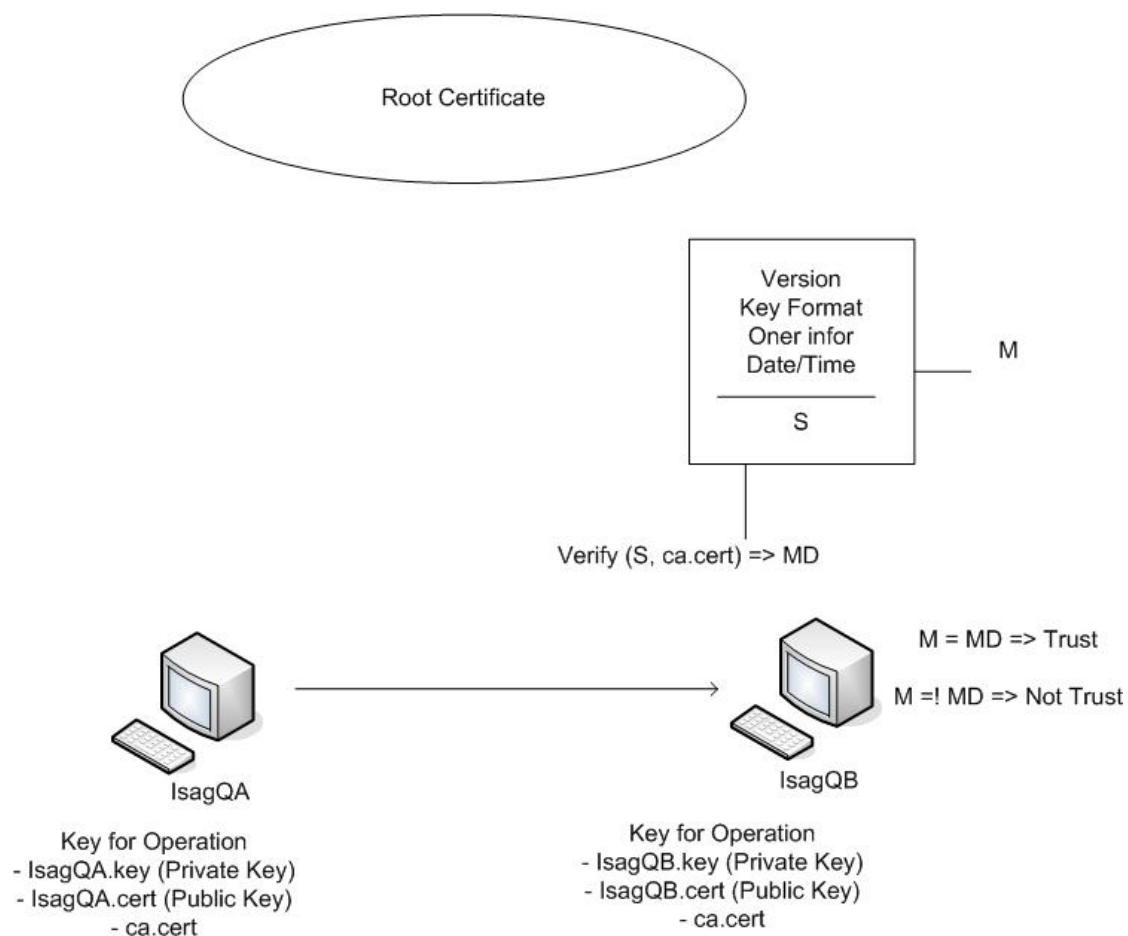
2.5.2 ขั้นตอนในการร้องขอใบรับรองดิจิทัล



รูปที่ 2.9 ขั้นตอนการร้องขอใบรับรองดิจิทัล

1. ผู้ร้องขอซึ่งในที่นี้จะประกอบด้วย IsagQA และ IsagQB จำเป็นต้องมีใบรับรองสิทธิ์ของ Root CA ซึ่งก็คือ IsagMQ เพื่อเก็บไว้ใช้ในระบบพิสูจน์ตน
2. เมื่อผู้ร้องขอมีใบรับรองสิทธิ์ของ IsagMQ แล้ว ก็ให้ทำการร้องขอไปยัง Root CA ก่อนที่ผู้ร้องขอจะส่ง .req ออกไป ผู้ร้องขอจำเป็นต้องมีไฟล์ 2 ชนิดคือ คือ IsagQA.key หรือ IsagQB.key ซึ่งก็คือกุญแจส่วนตัวของผู้ร้องขอและ IsagQA.req หรือ IsagQB ซึ่งก็คือไฟล์ที่ใช้ร้องขอไปยังผู้ออกใบรับรองสิทธิ์ โดยไฟล์ที่ร้องขอต้องถูกเข้ารหัสด้วย root.cert ก่อน เพื่อที่จะมั่นใจได้ว่า Root CA จะสามารถเปิดดูได้เพียงผู้เดียว
3. หลังจากที่ Root CA ได้รับ IsagQA.req หรือ IsagQB.req แล้วก็จะทำการแฮช(hash) แล้วนำค่านั้นมา sign ด้วย Root.key ผลลัพธ์ที่ได้จะได้อักษร S (Digital Signature) แล้วนำค่า S ที่ได้ไปเก็บไว้ใน IsagQA.cert หรือ IsagQB.cert
4. ผู้ออกใบรับรองสิทธิ์จะทำการส่ง IsagQA.cert หรือ IsagQB.cert คืนกลับให้ผู้ร้องขอ ขั้นตอนในการร้องขอใบรับรองสิทธิ์

2.5.3 การพิสูจน์ตนโดยใช้ใบรับรองสิทธิ์(Certificate Authentication)



รูปที่ 2.10 รูปแสดงการพิสูจน์ตัวตนโดยใช้ใบรับรองสิทธิ์

เพื่อเริ่มทำการพิสูจน์ตัวตน IsagQAก็จะส่ง(IsagQA.cert) ให้แก่IsagQBทำการพิสูจน์ตนของฝั่ง IsagQA เมื่อ IsagQB ได้รับไฟล์ IsagQA.cert ซึ่งไฟล์นี้ประกอบไปด้วยสองส่วนคือ ส่วนข้อมูลส่วนตัวของIsagQAและค่า S (Digital Signature) กระบวนการพิสูจน์ตนทางฝั่ง IsagQB คือ จะนำเอาข้อมูลส่วนตัวของIsagQAมาทำ MD5 ได้ค่าแฮช (hash) มาหนึ่งค่าคือค่า M จากนั้นนำค่า S ของIsagQAและกุญแจสาธารณะของ Root Certificate มาทำการตรวจสอบค่าที่ได้ออกมาคือ MD นำค่า M กับ MD มาเปรียบเทียบกับกัน ถ้าค่านั้นเท่ากันแสดงว่าการพิสูจน์ตัวตนนั้นถูกต้อง ถ้าไม่เท่ากันแสดงว่าการพิสูจน์ตนผิดพลาด

2.5.4 การแยกระหว่างพิสูจน์ตัวตนและการเข้ารหัส

การใช้ใบรับรองสิทธิ์เพียงอย่างเดียวในการทำทั้งการพิสูจน์ตัวตนและการเข้ารหัสข้อมูลนั้น เป็นวิธีการที่ไม่ดีนัก ยกตัวอย่างเช่นมีหลาย ๆ อัลกอริทึมที่ใช้ในการสร้างกุญแจสาธารณะ ที่มี

ไว้ใช้สำหรับการ Sign ข้อมูลเท่านั้น ไม่สามารถนำมาใช้ในการเข้ารหัสข้อมูลได้ เช่น DSA (Digital Signature Algorithm) ดังนั้นจึงมีการแยกข้อความระหว่างพิสูจน์ตนกับข้อความสำหรับการเข้ารหัส ซึ่งก็คือ เมื่อผู้ส่งข้อความ ส่งใบรับรองสิทธิ์ไปให้ผู้รับผู้รับก็จะตรวจสอบถ้าถูกต้องก็จะใช้กุญแจสาธารณะของผู้ส่งทำการเข้ารหัสกุญแจลับเพื่อทำกระบวนการ SSL ในขั้นต่อไป